

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT IoT (INT4410)

RỦI RO KHI MQTT KHÔNG MÃ HÓA

Mã đề tài	13
Sinh viên	Nguyễn Xuân Duy Tấn
Mã số sinh viên	231A010141
Lớp học phần	253INT441001
Giảng viên	Hồ Nhựt Minh

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Rủi ro khi MQTT không mã hóa
Mã đề tài	13
Sinh viên/ Nhóm	Nguyễn Xuân Duy Tấn– 231A010141
Repo GitHub	https://github.com/nxdtan1105/TieuLuan-MQTT-Security
Bản báo cáo	231A010141_NguyenXuanDuyTan_DeTai13_TieuLuan_CuoiKy.docx 231A010141_NguyenXuanDuyTan_DeTai13_TieuLuan_CuoiKy.pdf
Sản phẩm chính	Mô hình lab MQTT (Mosquitto Broker, Publisher/Subscriber Python), Bộ kịch bản kiểm thử kèm file lưu lượng mạng, Ma trận rủi ro bảo mật (STRIDE).
Ngày nộp	03/08/2026

Cam kết an toàn và học thuật

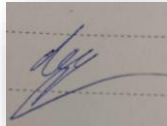
Em xin cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Báo cáo có sử dụng công cụ Trí tuệ nhân tạo (AI) hỗ trợ kiểm tra ngôn ngữ và chỉnh sửa câu văn, hình ảnh. Cụ thể trong quá trình thực hiện đề tài, em có sử dụng công cụ Google Gemini để hỗ trợ cho các công việc: chỉnh sửa ngữ pháp, hỗ trợ cấu trúc dàn ý và tối ưu hóa câu văn báo cáo. Các công cụ này chỉ đóng vai trò hỗ trợ; toàn bộ ý tưởng cốt lõi, phương pháp nghiên cứu, quá trình phân tích dữ liệu và kết luận của công trình đều do em tự thực hiện và hoàn toàn chịu trách nhiệm về nội dung, kết quả thực hiện và các kết luận trong báo cáo.

TP. Hồ Chí Minh, ngày 03 tháng 08 năm 2026

Người cam kết

(Ký và ghi rõ họ tên)



Nguyễn Xuân Duy Tấn

PHẦN A — CHECKLIST TIẾN ĐỘ THỰC HIỆN ĐỀ TÀI

Tuần / Giai đoạn	Nội dung công việc thực hiện	Trạng thái	Mình chứng (Số trang / Commit)
Tuần 01	Khảo sát bối cảnh, phát biểu vấn đề, xác định mục tiêu, đối tượng, phạm vi và hoàn thành cơ sở lý thuyết về giao thức MQTT, mô hình Publish/Subscribe, cơ chế bảo mật (Chương 1 và Chương 2)	☒ Đạt ☐ Bổ sung	Trang 8–15 (commit Tuan01)
Tuần 02	Thiết kế phương pháp thực hiện, xây dựng mô hình kiến trúc hệ thống MQTT, xác định môi trường, công cụ, quy trình triển khai và 5 tiêu chí đánh giá (Chương 3).	☒ Đạt ☐ Bổ sung	Trang 16–18 (commit Tuan02)
Tuần 03	Triển khai môi trường thực nghiệm cục bộ với Mosquitto Broker, Python, Wireshark; xây dựng thành phần sản phẩm và thực thi các kịch bản kiểm thử từ TC-01 đến TC-05 (Chương 4).	☒ Đạt ☐ Bổ sung	Trang 19–23 (commit Tuan03)
Tuần 04	Phân tích tài sản, mối đe dọa và lỗ hổng theo STRIDE, xây dựng ma trận rủi ro, đề xuất các biện pháp giảm thiểu và đánh giá rủi ro còn lại (Chương 5) và hoàn thành phần kết luận, hạn chế và định hướng phát triển đề tài (Chương 6)	☒ Đạt ☐ Bổ sung	Trang 24–26 (commit Tuan04)
Tuần 05	Kiểm tra tổng thể, định dạng báo cáo, đồng bộ toàn bộ tài liệu/sơ đồ lên GitHub và hoàn thiện gói nộp bài.	☒ Đạt ☐ Bổ sung	Trang 27–29 (commit Tuan05)
Repo	Có README và commit Tuần 02; link mở được.	☒ Đạt ☐ Bổ sung	<u>GitHub Repo</u>

MỤC LỤC

THÔNG TIN VÀ CAM KẾT NỘP BÀI	2
Cam kết an toàn và học thuật.....	2
PHẦN A — CHECKLIST TIẾN ĐỘ THỰC HIỆN ĐỀ TÀI.....	3
DANH MỤC TỪ VIẾT TẮT	6
DANH MỤC HÌNH ẢNH.....	7
DANH MỤC BẢNG.....	7
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	8
1.1. Bối cảnh và lý do chọn đề tài	8
1.2. Phát biểu vấn đề	8
1.3. Mục tiêu của đề tài	9
1.4. Đối tượng, phạm vi và giới hạn an toàn	9
1.5. Sản phẩm dự kiến và đóng góp	9
1.6. Cấu trúc báo cáo	10
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	11
2.1. Kiến trúc, giao thức hoặc công nghệ nền	11
2.2. Khái niệm bảo mật liên quan	12
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài	13
2.4. Chuẩn, tài liệu và công cụ GitHub	14
2.5. Công trình hoặc giải pháp liên quan	15
2.6. Tiểu kết Chương 2	16
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	17
3.1. Phương pháp thực hiện	17
3.2. Mô hình/kiến trúc đề xuất	17
3.3. Môi trường, công cụ và dữ liệu	18
3.4. Quy trình triển khai	19
3.5. Tiêu chí đánh giá	20
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ	22
4.1. Chuẩn bị môi trường	22
4.2. Thành phần sản phẩm	22
4.3. Kịch bản thử nghiệm/đánh giá	23

4.4. Kết quả	24
4.5. Script sinh báo cáo	25
4.6. Thảo luận và hạn chế	26
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	27
5.1. Tài sản và dữ liệu	27
5.2. Mối đe dọa và lỗ hổng	27
5.3. Ma trận rủi ro	28
5.4. Biện pháp giảm thiểu	28
5.5. Rủi ro còn lại	28
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	30
6.1. Kết luận	30
6.2. Hạn chế	30
6.3. Hướng phát triển	30
TÀI LIỆU THAM KHẢO	31
PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP	32
PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP	32
PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP	33

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	ACL	Access Control List (Danh sách kiểm soát truy cập)
2	API	Application Programming Interface (Giao diện lập trình ứng dụng)
3	C-I-A	Confidentiality, Integrity, Availability (Tính bí mật, tính toàn vẹn, tính sẵn sàng)
4	DDoS	Distributed Denial of Service (Tấn công từ chối dịch vụ phân tán)
5	DoS	Denial of Service (Tấn công từ chối dịch vụ)
6	IoT	Internet of Things (Mạng lưới thiết bị kết nối Internet)
7	IP	Internet Protocol (Giao thức mạng Internet)
8	LAN	Local Area Network (Mạng máy tính cục bộ)
9	MAC	Message Authentication Code (Mã xác thực thông điệp)
10	MQTT	Message Queuing Telemetry Transport (Giao thức truyền thông tin IoT nhẹ)
11	RAM	Random Access Memory (Bộ nhớ truy cập ngẫu nhiên)
12	SSL	Secure Sockets Layer (Lớp cổng bảo mật)
13	TCP	Transmission Control Protocol (Giao thức điều khiển truyền tải)
14	TLS	Transport Layer Security (Bảo mật tầng truyền tải)
15	CPU	Central Processing Unit (Bộ xử lý trung tâm)
16	HTML	HyperText Markup Language
17	PDF	Portable Document Format
18	QoS	Quality of Service (Chất lượng dịch vụ truyền thông điệp)

DANH MỤC HÌNH ẢNH

Hình 2.1: Cấu hình kiến trúc hệ thống MQTT – Mô hình Publish/Subscribe.....	11
Hình 3.2. Mô hình hệ thống thực nghiệm MQTT(draw.io)	16
Hình 4.1: Môi trường thực nghiệm MQTT chạy cục bộ, gồm Mosquitto Broker (dưới cùng), Publisher (trên trái) và Subscriber (trên phải) đang truyền nhận thông điệp thành công	19

DANH MỤC BẢNG

Bảng 1.1. Bảng đối chiếu mục tiêu và đầu ra của đề tài	10
Bảng 2.1. So sánh đặc điểm giữa MQTT không mã hóa và MQTT sử dụng TLS	13
Bảng 2.2. Danh mục chuẩn, tài liệu và nguồn GitHub tham chiếu.....	14
Bảng 2.3. Tổng hợp các nghiên cứu, giải pháp liên quan và phạm vi đề tài	15
Bảng 3.1. Danh mục các thành phần, công cụ và thông số môi trường thực nghiệm.....	17
Bảng 3.2. Quy trình thực hiện kiểm thử hệ thống MQTT	17
Bảng 4.1. Cấu trúc lưu trữ mã nguồn và tài liệu trên kho GitHub.....	20
Bảng 4.2. Bộ kịch bản kiểm thử (Test Cases) đánh giá bảo mật MQTT	21
Bảng 4.3. Bảng tổng hợp kết quả thực nghiệm kiểm thử MQTT	22
Bảng 5.1. Bảng phân tích tài sản và dữ liệu cần bảo vệ trong hệ thống MQTT	24
Bảng 5.2. Phân tích mối đe dọa và lỗ hổng theo mô hình STRIDE	24
Bảng 5.3. Ma trận đánh giá rủi ro (Risk Register) hệ thống MQTT	25

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong các hệ thống Internet of Things (IoT), các thiết bị có khả năng thu thập dữ liệu từ môi trường và trao đổi dữ liệu với các thiết bị, máy chủ hoặc ứng dụng thông qua mạng. Để thực hiện việc trao đổi dữ liệu giữa các thành phần có tài nguyên hạn chế, các giao thức truyền thông nhẹ thường được sử dụng. MQTT là một trong những giao thức được thiết kế cho mô hình truyền thông publish/subscribe, phù hợp với các hệ thống IoT có yêu cầu trao đổi dữ liệu thường xuyên và sử dụng băng thông hạn chế.

Trong một hệ thống MQTT, các thiết bị hoặc ứng dụng có thể đóng vai trò publisher để gửi dữ liệu lên broker, trong khi subscriber nhận dữ liệu từ các topic đã đăng ký. Broker thực hiện nhiệm vụ tiếp nhận và phân phối thông điệp giữa các thành phần. Mô hình này giúp giảm sự phụ thuộc trực tiếp giữa bên gửi và bên nhận, đồng thời phù hợp với nhiều mô hình triển khai IoT.

Tuy nhiên, việc sử dụng MQTT mà không có cơ chế mã hóa kênh truyền có thể tạo ra rủi ro bảo mật. Khi dữ liệu được truyền qua mạng dưới dạng không được bảo vệ đầy đủ, thông tin trao đổi giữa client và broker có nguy cơ bị quan sát hoặc thu thập bởi một thành phần nằm trên đường truyền. Điều này đặc biệt đáng quan tâm đối với các hệ thống IoT có dữ liệu cần bảo vệ hoặc có yêu cầu về tính bí mật và toàn vẹn.

Đề tài “Rủi ro khi MQTT không mã hóa” được lựa chọn nhằm tìm hiểu rõ hơn những rủi ro bảo mật phát sinh khi MQTT được triển khai mà không có cơ chế bảo vệ phù hợp cho kênh truyền. Đề tài tập trung vào đặc tính của giao thức MQTT, luồng trao đổi dữ liệu giữa client và broker, cơ chế xác thực – mã hóa và việc đánh giá rủi ro trong môi trường lab được kiểm soát.

Việc nghiên cứu vấn đề này có ý nghĩa trong việc giúp người triển khai hệ thống IoT nhận biết được sự khác biệt giữa một kết nối MQTT không được bảo vệ và một mô hình có cơ chế bảo mật phù hợp. Từ đó, có thể đề xuất các biện pháp giảm thiểu rủi ro và xây dựng quy trình kiểm tra bảo mật cho hệ thống MQTT.

1.2. Phát biểu vấn đề bảo mật

Trong mô hình nghiên cứu, các tài sản cần bảo vệ bao gồm thông điệp MQTT được trao đổi giữa client và broker, thông tin cấu hình của hệ thống, thông tin xác thực nếu có sử dụng và tính tin cậy của quá trình trao đổi dữ liệu. Khi dữ liệu được truyền qua một kênh không được bảo vệ, dữ liệu có thể có nguy cơ bị quan sát bởi thành phần không được phép trên đường truyền.

Mối đe dọa được nghiên cứu là khả năng một đối tượng nằm trong phạm vi mạng thử nghiệm có thể quan sát lưu lượng MQTT và thu thập thông tin được truyền giữa client và broker. Lỗ hổng hoặc điểm yếu trọng tâm là việc sử dụng kết nối MQTT không được mã hóa, khiến dữ liệu truyền qua mạng không có lớp bảo vệ mật mã tương ứng.

Hậu quả của vấn đề có thể ảnh hưởng đến tính bí mật của dữ liệu. Trong một số trường hợp, nếu các cơ chế kiểm soát truy cập và xác thực cũng được cấu hình không phù hợp, rủi ro có thể tiếp tục ảnh hưởng đến tính toàn vẹn hoặc khả năng kiểm soát việc truy cập các topic MQTT.

Do đó, đề tài tập trung nghiên cứu và minh họa rủi ro trong môi trường lab/mô phỏng được kiểm soát, không thực hiện trên hệ thống thật hoặc thiết bị không thuộc quyền sở hữu của người thực hiện.

1.3. Mục tiêu của đề tài

Đề tài được xây dựng với các mục tiêu có thể kiểm chứng thông qua sản phẩm và kết quả thử nghiệm.

MT-01: Mô tả được kiến trúc và luồng trao đổi dữ liệu của một hệ thống MQTT gồm client, broker và các thành phần liên quan.

MT-02: Phân tích được đặc điểm bảo mật của MQTT khi kênh truyền không được mã hóa, tập trung vào nguy cơ đối với tính bí mật của dữ liệu.

MT-03: Xây dựng được môi trường lab MQTT phục vụ việc quan sát và đánh giá rủi ro trong phạm vi an toàn, sử dụng dữ liệu thử nghiệm.

MT-04: Xây dựng và thực hiện các kịch bản kiểm thử để minh họa sự khác biệt về mức độ bảo vệ dữ liệu giữa cấu hình MQTT không mã hóa và cấu hình có biện pháp bảo vệ phù hợp.

MT-05: Đề xuất các biện pháp giảm thiểu rủi ro và đánh giá rủi ro còn lại sau khi áp dụng biện pháp bảo vệ.

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu của đề tài là giao thức MQTT và mô hình trao đổi dữ liệu giữa MQTT client và MQTT broker trong môi trường IoT. Nội dung tập trung vào cơ chế truyền thông, kênh mạng, thông điệp MQTT và các cơ chế xác thực, mã hóa có liên quan đến việc bảo vệ dữ liệu.

Phạm vi thực hiện được giới hạn trong môi trường lab hoặc mô phỏng do sinh viên chủ động xây dựng. Các thành phần có thể bao gồm MQTT broker, MQTT client và công cụ quan sát lưu lượng mạng. Dữ liệu sử dụng trong quá trình kiểm thử là dữ liệu giả lập, không sử dụng thông tin cá nhân hoặc dữ liệu nhạy cảm của người khác.

Đề tài tập trung vào trường hợp MQTT không mã hóa và các rủi ro liên quan đến việc truyền dữ liệu qua mạng. Sau đó, các biện pháp bảo vệ phù hợp sẽ được xem xét nhằm đánh giá khả năng giảm thiểu rủi ro.

Về giới hạn an toàn, các hoạt động kiểm thử chỉ được thực hiện trong môi trường do sinh viên sở hữu hoặc được phép sử dụng. Đề tài không thực hiện việc nghe lén, can thiệp hoặc kiểm thử trái phép trên hệ thống MQTT của tổ chức, cá nhân hoặc thiết bị IoT ngoài phạm vi lab.

1.5. Sản phẩm và kết quả dự kiến

Các sản phẩm và kết quả dự kiến của đề tài gồm:

Báo cáo tiểu luận hoàn chỉnh về rủi ro khi MQTT không mã hóa.

Sơ đồ kiến trúc và luồng dữ liệu của hệ thống MQTT.

Mô hình lab MQTT phục vụ kiểm thử.

Cấu hình MQTT broker và client phục vụ các kịch bản thử nghiệm.

Các kịch bản kiểm thử liên quan đến MQTT không mã hóa.

Log hoặc ảnh chụp kết quả thử nghiệm làm minh chứng.

Bảng tổng hợp kết quả kiểm thử.

Phân tích tài sản, mối đe dọa, lỗ hổng và rủi ro.

Ma trận đánh giá rủi ro.

Đề xuất biện pháp giảm thiểu, bao gồm các cơ chế bảo vệ kênh truyền và kiểm soát truy cập phù hợp.

Repository GitHub chứa README, cấu hình, mã nguồn hoặc script, log, hình ảnh minh chứng và các tài liệu liên quan.

1.6. Cấu trúc báo cáo

Báo cáo được tổ chức thành sáu chương. Chương 1 trình bày bối cảnh, vấn đề bảo mật, mục tiêu, phạm vi và các sản phẩm dự kiến của đề tài. Chương 2 trình bày cơ sở lý thuyết liên quan đến IoT, MQTT, mô hình truyền thông, các khái niệm bảo mật và các cơ chế xác thực – mã hóa có liên quan. Chương 3 trình bày phương pháp thực hiện, mô hình kiến trúc, môi trường, công cụ, quy trình triển khai và tiêu chí đánh giá. Chương 4 trình bày quá trình triển khai lab, các kịch bản thử nghiệm và kết quả thu được. Chương 5 phân tích tài sản, mối đe dọa, lỗ hổng, ma trận rủi ro và các biện pháp giảm thiểu. Cuối cùng, Chương 6 tổng kết kết quả đạt được, nêu hạn chế và đề xuất hướng phát triển.

Bảng đối chiếu mục tiêu và đầu ra

Bảng 1.1. Bảng đối chiếu mục tiêu và đầu ra của đề tài

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Sơ đồ kiến trúc/luồng dữ liệu	Kiểm tra sơ đồ và mô tả các thành phần	Chương 2, Chương 3
MT-02	Phân tích đặc điểm giao thức và rủi ro bảo mật	Đối chiếu với kịch bản và dữ liệu thử nghiệm	Chương 2, Chương 5
MT-03	Broker, client, cấu hình và dữ liệu thử nghiệm	Kiểm tra môi trường chạy và log	Chương 3, Chương 4
MT-04	Bảng kịch bản, log và ảnh minh chứng	Đối chiếu kết quả thực tế với kết quả kỳ vọng	Chương 4
MT-05	Bảng biện pháp, ma trận rủi ro và rủi ro còn lại	So sánh rủi ro trước và sau khi áp dụng biện pháp	Chương 5, Chương 6

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

MQTT (Message Queuing Telemetry Transport) là một giao thức truyền thông theo mô hình Client/Server và sử dụng cơ chế publish/subscribe. Giao thức được thiết kế theo hướng nhẹ, đơn giản và phù hợp với các môi trường có tài nguyên hoặc băng thông hạn chế, trong đó có các hệ thống Internet of Things (IoT). Theo đặc tả MQTT 5.0 của OASIS, MQTT sử dụng mô hình publish/subscribe nhằm phân tách bên gửi và bên nhận thông điệp thông qua một thành phần trung gian là MQTT Server/Broker.

Trong phạm vi đề tài, hệ thống MQTT được mô hình hóa gồm ba thành phần chính: MQTT Publisher/Client, MQTT Broker và MQTT Subscriber/Client.

MQTT Publisher/Client là thiết bị hoặc chương trình gửi dữ liệu lên một topic. Trong hệ thống IoT, publisher có thể đại diện cho cảm biến hoặc thiết bị thu thập dữ liệu. Dữ liệu được đóng gói thành MQTT message và gửi đến broker.

MQTT Broker là thành phần trung gian chịu trách nhiệm tiếp nhận các kết nối từ client, nhận thông điệp publish và phân phối thông điệp đến các client đã đăng ký topic tương ứng. Broker giúp publisher và subscriber không cần thiết lập kết nối trực tiếp với nhau.

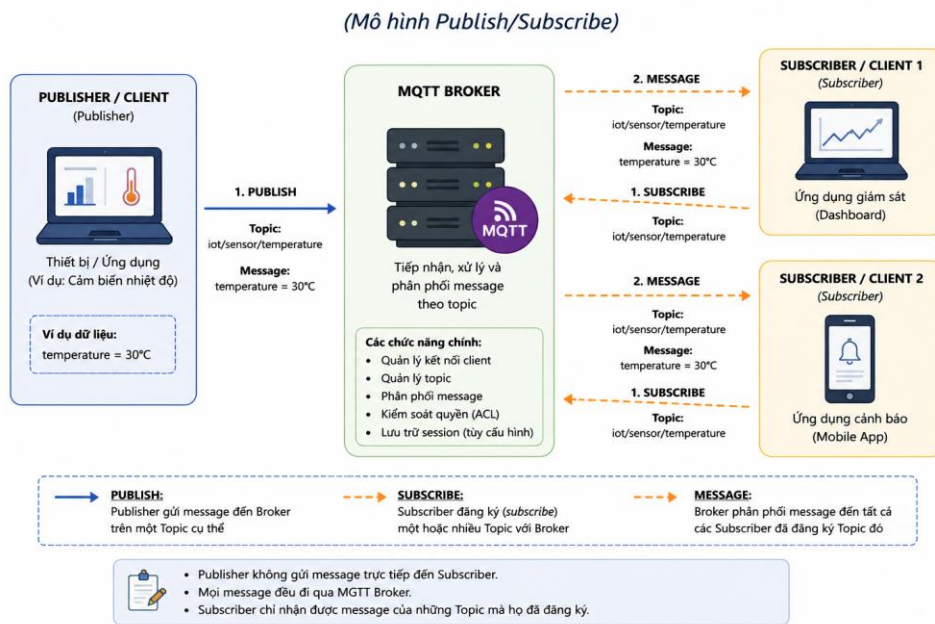
MQTT Subscriber/Client là thiết bị hoặc chương trình đăng ký một hoặc nhiều topic để nhận thông điệp từ broker. Khi broker nhận được một message phù hợp với topic mà subscriber đã đăng ký, broker sẽ chuyển message đến subscriber.

Luồng dữ liệu cơ bản của hệ thống được mô tả như sau:

Publisher → MQTT Broker → Subscriber

Ví dụ, một client có thể gửi dữ liệu cảm biến lên topic `iot/sensor/temperature`. Broker tiếp nhận message này và chuyển đến các subscriber đã đăng ký topic tương ứng.

Trong trường hợp nghiên cứu của đề tài, kết nối MQTT được triển khai trong môi trường lab. Trường hợp trọng tâm là kết nối MQTT không được bảo vệ bằng lớp mã hóa truyền tải. Khi đó, dữ liệu MQTT đi qua mạng có thể không được bảo vệ về tính bí mật. Đặc tả MQTT cũng chỉ ra rằng các giải pháp MQTT cần xem xét những vấn đề như xác thực, phân quyền, tính toàn vẹn và tính riêng tư của dữ liệu.



Hình 2.1: Cấu hình kiến trúc hệ thống MQTT – Mô hình Publish/Subscribe

2.2. Khái niệm bảo mật trực tiếp liên quan

Trong hệ thống MQTT, bảo mật cần được xem xét đối với dữ liệu, thiết bị, thông tin xác thực và kênh truyền giữa client với broker. Đối với đề tài này, các khái niệm quan trọng gồm tài sản, mối đe dọa, lỗ hổng và rủi ro.

Tài sản là những dữ liệu hoặc thành phần cần được bảo vệ. Trong hệ thống nghiên cứu, tài sản chính bao gồm nội dung message MQTT, thông tin cấu hình của broker và client, thông tin xác thực cũng như dữ liệu được truyền giữa các thành phần.

Mối đe dọa là khả năng một tác nhân hoặc sự kiện gây ảnh hưởng đến tài sản. Với MQTT không mã hóa, mối đe dọa đáng chú ý là khả năng lưu lượng truyền giữa client và broker bị quan sát, từ đó làm lộ nội dung message.

Lỗ hổng là điểm yếu có thể bị khai thác để gây ảnh hưởng đến hệ thống. Trong phạm vi đề tài, điểm yếu được nghiên cứu là việc sử dụng kết nối MQTT không được bảo vệ bằng cơ chế mã hóa kênh truyền phù hợp.

Rủi ro phát sinh khi một mối đe dọa có khả năng khai thác điểm yếu và gây tác động đến tài sản. Rủi ro trọng tâm của đề tài là nguy cơ mất tính bí mật của dữ liệu MQTT khi được truyền qua một kênh không được mã hóa.

Bên cạnh đó, bảo mật MQTT còn liên quan đến **xác thực, phân quyền và mã hóa**. Xác thực giúp xác định danh tính client; phân quyền xác định client được phép thực hiện những thao tác nào trên các topic; còn mã hóa kênh truyền giúp bảo vệ dữ liệu trong quá trình trao đổi. Vì vậy, việc xác thực client không đồng nghĩa với việc dữ liệu truyền trên mạng đã được bảo vệ khỏi nguy cơ bị quan sát.

Đối với MQTT, TLS có thể được sử dụng để bảo vệ kết nối TCP. Đặc tả MQTT 3.1.1 đề cập đến việc sử dụng TLS và port 8883 cho secure-MQTT. Đây cũng là cơ sở để đề tài so sánh giữa kết nối MQTT không mã hóa và kết nối được bảo vệ bằng TLS.

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

Đề tài 13 thuộc **hướng B**, do đó trọng tâm của chương này là đặc tính giao thức/mạng/API, cơ chế xác thực – mã hóa và cấu hình an toàn. Nội dung này phù hợp với yêu cầu của mẫu báo cáo đối với nhóm đề tài 11–19 và 49.

2.3.1. Đặc điểm giao thức MQTT

MQTT sử dụng mô hình publish/subscribe. Publisher gửi message tới một topic thông qua broker, trong khi subscriber đăng ký topic để nhận dữ liệu. Cách tổ chức này tạo ra sự tách biệt giữa bên gửi và bên nhận, phù hợp với các hệ thống IoT. OASIS mô tả MQTT là một giao thức client-server publish/subscribe nhẹ và được thiết kế để triển khai đơn giản.

MQTT hoạt động trên một kết nối mạng hai chiều và có thể sử dụng TCP/IP hoặc các giao thức truyền tải cung cấp kết nối hai chiều có thứ tự và đáng tin cậy.

2.3.2. Topic và Message

Topic là tên logic được sử dụng để phân loại và định tuyến message trong hệ thống MQTT. Publisher gửi message tới một topic, còn subscriber đăng ký topic để nhận dữ liệu.

Ví dụ:

iot/sensor/temperature

Một publisher có thể gửi:

temperature=30

Broker sẽ phân phối message đến subscriber đã đăng ký topic tương ứng.

Trong thực tế, việc thiết kế topic cần kết hợp với cơ chế phân quyền để hạn chế client truy cập những topic không thuộc phạm vi được phép.

2.3.3. MQTT Broker

Broker là trung tâm của mô hình publish/subscribe. Broker tiếp nhận kết nối client, xử lý các yêu cầu MQTT và phân phối message.

Do broker đóng vai trò trung gian, việc bảo vệ broker và cấu hình quyền truy cập topic là một phần quan trọng của bảo mật MQTT.

2.3.4. Xác thực và phân quyền

Đặc tả MQTT có các cơ chế liên quan đến xác thực client và kiểm soát quyền truy cập. Tuy nhiên, việc xác thực danh tính không đồng nghĩa với việc dữ liệu truyền trên mạng đã được bảo vệ khỏi việc quan sát.

Do đó, khi xây dựng hệ thống an toàn cần xem xét đồng thời:

1. Xác thực client.
2. Phân quyền truy cập topic.

3. Bảo vệ kết nối truyền tải.
4. Bảo vệ thông tin xác thực.
5. Quản lý chứng chỉ và khóa khi sử dụng TLS.

2.3.5. MQTT không mã hóa và MQTT có bảo vệ TLS

Bảng 2.1. So sánh đặc điểm giữa MQTT không mã hóa và MQTT sử dụng TLS

Đặc điểm	MQTT không mã hóa	MQTT sử dụng TLS
Giao thức ứng dụng	MQTT	MQTT
Kết nối truyền tải	TCP	TCP + TLS
Bảo vệ dữ liệu trên đường truyền	Không có lớp mã hóa truyền tải	Có lớp TLS
Nguy cơ quan sát dữ liệu trên đường truyền	Cao hơn	Được giảm đáng kể
Xác thực	Có thể cấu hình riêng	Có thể kết hợp xác thực với TLS
Port thường gặp	1883	8883
Mục đích trong đề tài	Kịch bản cần nghiên cứu	Kịch bản đối chiếu/giảm thiểu

Port 8883 được đặc tả MQTT 3.1.1 đề cập cho trường hợp triển khai TLS.

2.4. Chuẩn, công cụ và nguồn GitHub chính

Bảng 2.2. Danh mục chuẩn, tài liệu và nguồn GitHub tham chiếu

ST T	Nguồn/repo	URL/phiên bản	Phần đã sử dụng	Truy cập
1	OASIS – MQTT Version 5.0	https://docs.oasis-open.org/mqtt/mqtt/v5.0/?utm_source=chatgpt.com	Kiến trúc MQTT, Client/Broker, Publish/Subscribe	02/08/2026
2	OASIS – MQTT Version 3.1.1	https://docs.oasis-open.org/mqtt/mqtt/v3.1.1/?utm_source=chatgpt.com	TCP, TLS và bảo mật kết nối	02/08/2026
3	NIST – Cybersecurity for IoT	https://www.nist.gov/itl/applied-cybersecurity/nist-cybersecurity-iot-program?utm_source=chatgpt.com	Cơ sở bảo mật IoT	02/08/2026

ST T	Nguồn/repo	URL/phiên bản	Phần đã sử dụng	Truy cập
4	OWASP – Internet of Things Project	https://owasp.org/www-project-internet-of-things/?utm_source=chatgpt.com	Tham khảo rủi ro bảo mật IoT	02/08/2026
5	GitHub – Repository của sinh viên	https://github.com/nxdtan1105/TieuLuan-MQTT-Security	Lưu trữ tài liệu, hình ảnh, thực nghiệm và kết quả	02/08/2026

2.5. Công trình hoặc giải pháp liên quan

Hiện nay, vấn đề bảo mật trong giao thức MQTT đã được nghiên cứu theo nhiều hướng khác nhau, đặc biệt trong các hệ thống Internet of Things (IoT). Các nghiên cứu tập trung vào việc phân tích những nguy cơ có thể xảy ra trong quá trình trao đổi dữ liệu giữa MQTT Client và Broker, đồng thời đề xuất các cơ chế nhằm tăng cường tính an toàn cho hệ thống.

Một trong những hướng bảo vệ phổ biến là sử dụng **TLS** để mã hóa kênh truyền giữa Client và Broker. Khi được triển khai phù hợp, TLS giúp bảo vệ dữ liệu khỏi nguy cơ bị đọc hoặc thay đổi trong quá trình truyền. Ngoài mã hóa, hệ thống MQTT còn có thể kết hợp các cơ chế xác thực và phân quyền để hạn chế việc truy cập trái phép vào Broker và các Topic.

Bên cạnh đó, một số nghiên cứu cũng tập trung vào việc đánh giá các rủi ro khi MQTT được triển khai với cấu hình bảo mật không đầy đủ. Những vấn đề thường được quan tâm bao gồm khả năng dữ liệu bị lộ trên đường truyền, xác thực yếu, kiểm soát quyền truy cập chưa phù hợp và các dịch vụ mạng được cấu hình không an toàn. Đây là những vấn đề cần được xem xét khi triển khai MQTT trong môi trường IoT thực tế.

Từ các hướng nghiên cứu trên, đề tài **“Rủi ro khi MQTT không mã hóa”** tập trung vào một phạm vi cụ thể là đánh giá nguy cơ đối với dữ liệu khi MQTT được sử dụng mà không có cơ chế bảo vệ kênh truyền. Đề tài kế thừa mô hình Client–Broker–Client và các khái niệm bảo mật MQTT, sau đó xây dựng môi trường thực nghiệm để quan sát sự khác biệt giữa kết nối không mã hóa và kết nối được bảo vệ.

Bảng 2.3. Tổng hợp các nghiên cứu, giải pháp liên quan và phạm vi đề tài

Nội dung	Các nghiên cứu/giải pháp liên quan	Đề tài thực hiện
Kiến trúc MQTT	Client, Broker, Publish/Subscribe	Kế thừa mô hình Client–Broker–Client
Bảo vệ dữ liệu	Sử dụng TLS để bảo vệ kênh truyền	Đánh giá rủi ro khi không sử dụng mã hóa
Xác thực	Username/Password và các cơ chế xác thực	Xem xét vai trò của xác thực trong giảm thiểu rủi ro

Nội dung	Các nghiên cứu/giải pháp liên quan	Đề tài thực hiện
Phân quyền	Kiểm soát quyền truy cập Topic	Đề cập trong quá trình đánh giá bảo mật
Thực nghiệm	Phân tích và đánh giá các nguy cơ MQTT	Quan sát và đánh giá dữ liệu truyền trong môi trường lab

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày những cơ sở lý thuyết cần thiết cho việc nghiên cứu rủi ro khi MQTT không mã hóa. Nội dung tập trung vào kiến trúc MQTT, mô hình Publish/Subscribe, vai trò của MQTT Client và Broker, Topic và Message, đồng thời làm rõ các khái niệm liên quan đến bảo mật như tài sản, mối đe dọa, lỗ hổng và rủi ro. Chương cũng phân tích những nguy cơ có thể phát sinh khi dữ liệu MQTT được truyền qua kênh không được mã hóa và vai trò của các cơ chế bảo vệ như TLS, xác thực và phân quyền.

Bên cạnh cơ sở lý thuyết, chương đã tổng hợp các tiêu chuẩn, tài liệu và công trình liên quan đến bảo mật MQTT và IoT. Từ đó, đề tài xác định phạm vi nghiên cứu tập trung vào việc đánh giá rủi ro khi MQTT không sử dụng cơ chế mã hóa cho kênh truyền. Những nội dung này là cơ sở để xây dựng phương pháp, môi trường thực nghiệm, kịch bản kiểm thử và tiêu chí đánh giá được trình bày trong **Chương 3**.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp **nghiên cứu lý thuyết kết hợp thực nghiệm trong môi trường lab**. Trước tiên, nhóm tìm hiểu kiến trúc, nguyên lý hoạt động và các cơ chế bảo mật của giao thức MQTT thông qua các tài liệu kỹ thuật và nguồn tham khảo liên quan. Trên cơ sở đó, các rủi ro phát sinh khi MQTT không sử dụng cơ chế mã hóa cho kênh truyền được xác định và phân tích.

Sau phân lý thuyết, môi trường thử nghiệm MQTT được xây dựng với mô hình Client–Broker–Client. Các thiết bị hoặc chương trình MQTT Client thực hiện gửi và nhận dữ liệu thông qua Broker. Trong quá trình thực nghiệm, lưu lượng truyền giữa Client và Broker được quan sát để đánh giá khả năng bảo vệ dữ liệu khi sử dụng kết nối không mã hóa.

Phương pháp thực hiện được chia thành các bước chính:

Tìm hiểu lý thuyết → Thiết kế môi trường lab → Xây dựng cấu hình MQTT → Thực hiện kiểm thử → Thu thập kết quả → Phân tích rủi ro → Đề xuất biện pháp giảm thiểu.

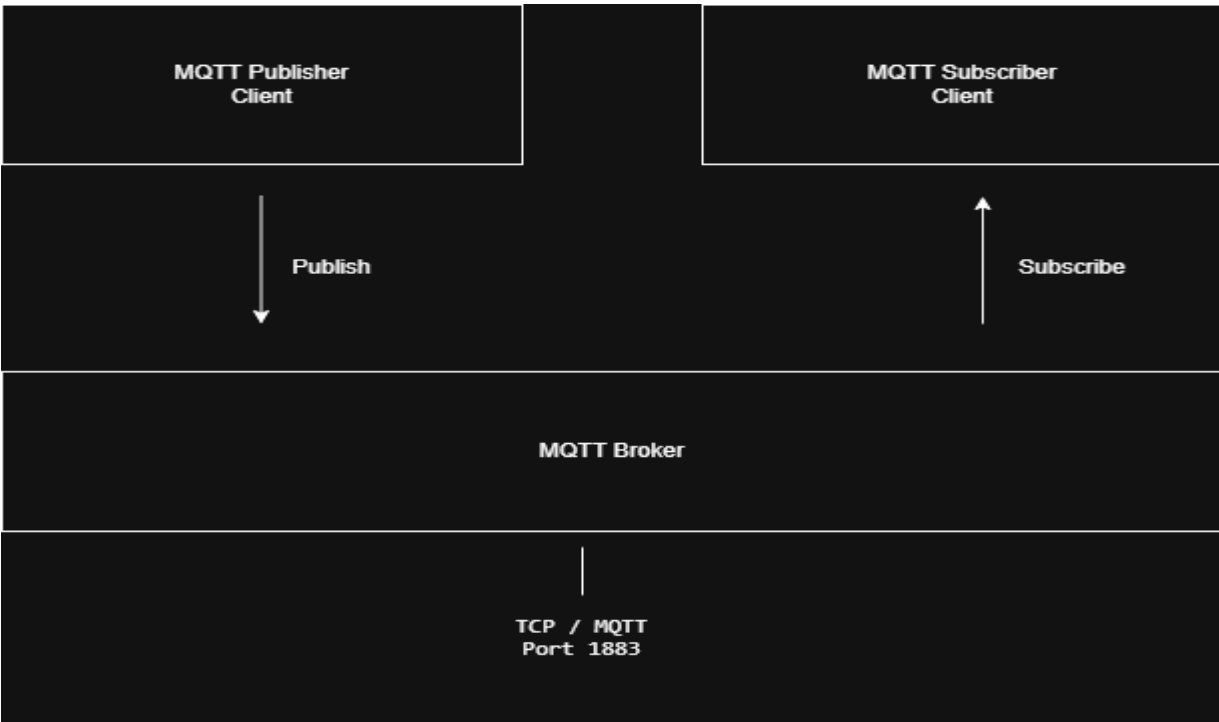
3.2. Mô hình/kiến trúc đề xuất

Môi trường thực nghiệm được thiết kế theo mô hình MQTT cơ bản gồm các thành phần chính là **MQTT Publisher, MQTT Broker và MQTT Subscriber**.

Publisher có nhiệm vụ tạo và gửi message đến một Topic thông qua Broker. Broker tiếp nhận message và phân phối đến các Client đã đăng ký Topic tương ứng. Subscriber thực hiện đăng ký Topic và nhận message từ Broker.

Để phục vụ mục tiêu của đề tài, hệ thống tập trung vào việc quan sát quá trình truyền dữ liệu trong trường hợp MQTT sử dụng kết nối **không mã hóa**. Dữ liệu thử nghiệm được lựa chọn ở mức đơn giản, không chứa thông tin cá nhân hoặc dữ liệu thực tế.

Mô hình tổng quát:



Hình 3.2. Mô hình hệ thống thực nghiệm MQTT(draw.io)

Trong giai đoạn đầu, hệ thống sử dụng kết nối MQTT không mã hóa để làm cơ sở đánh giá rủi ro. Sau đó, nếu môi trường thực nghiệm đáp ứng điều kiện, có thể triển khai thêm cấu hình bảo vệ để so sánh kết quả.

3.3. Môi trường, công cụ và dữ liệu

Môi trường thực nghiệm được xây dựng trên máy tính cá nhân, sử dụng mạng nội bộ để tạo điều kiện cho các thành phần MQTT có thể kết nối và trao đổi dữ liệu. Hệ thống được thiết kế ở quy mô nhỏ, tập trung vào việc quan sát quá trình truyền message giữa MQTT Client và MQTT Broker.

Các công cụ được lựa chọn phục vụ cho quá trình xây dựng và kiểm thử hệ thống MQTT. Công cụ lập trình được sử dụng để tạo MQTT Publisher và MQTT Subscriber, trong khi công cụ phân tích lưu lượng mạng được sử dụng để quan sát các gói tin được truyền giữa Client và Broker. Các công cụ và phiên bản cụ thể sẽ được ghi nhận lại trong quá trình triển khai thực nghiệm để bảo đảm kết quả có thể kiểm tra và tái hiện.

Dữ liệu sử dụng trong quá trình kiểm thử là các message mẫu được tạo riêng cho môi trường thực nghiệm. Nội dung dữ liệu không sử dụng thông tin cá nhân hoặc dữ liệu nhạy cảm thực tế. Các message được gửi qua một hoặc một số Topic MQTT được xác định trước nhằm phục vụ việc quan sát và đánh giá khả năng bảo vệ dữ liệu khi MQTT sử dụng kết nối không mã hóa.

Các thông số chính của môi trường thực nghiệm được tổng hợp như sau:

Bảng 3.1. Danh mục các thành phần, công cụ và thông số môi trường thực nghiệm

Thành phần	Mô tả
Thiết bị	Máy tính cá nhân phục vụ thực nghiệm

Thành phần	Mô tả
Mạng	Mạng nội bộ phục vụ kết nối giữa các thành phần
MQTT Client	Publisher và Subscriber
MQTT Broker	Thành phần trung gian tiếp nhận và phân phối message
Giao thức	MQTT
Kết nối kiểm thử	TCP
Port	1883
Dữ liệu	Message thử nghiệm, không chứa dữ liệu cá nhân
Phân tích	Quan sát và thu thập lưu lượng mạng

3.4. Quy trình triển khai/đánh giá

Quá trình kiểm thử được thực hiện nhằm đánh giá rủi ro khi giao thức MQTT truyền dữ liệu qua kết nối không mã hóa. Môi trường kiểm thử sử dụng mô hình gồm MQTT Publisher, MQTT Broker và MQTT Subscriber. Publisher gửi các message thử nghiệm đến Broker, sau đó Broker phân phối message đến Subscriber. Trong quá trình này, lưu lượng mạng giữa Client và Broker được quan sát để xác định những thông tin có thể nhìn thấy khi dữ liệu không được mã hóa.

Các message sử dụng trong quá trình kiểm thử là dữ liệu mẫu, không chứa thông tin cá nhân hoặc dữ liệu nhạy cảm thực tế. Kết quả được ghi nhận bằng hình ảnh chụp màn hình và log để phục vụ cho việc phân tích ở chương sau.

Bảng 3.2. Quy trình thực hiện kiểm thử hệ thống MQTT

STT	Kịch bản	Nội dung thực hiện	Kết quả cần ghi nhận
1	Kiểm tra kết nối MQTT	Khởi động Broker và cho Publisher, Subscriber kết nối thông qua TCP port 1883	Client kết nối thành công với Broker
2	Gửi message thử nghiệm	Publisher gửi message đến Topic đã xác định	Message được Broker tiếp nhận và chuyển đến Subscriber
3	Quan sát lưu lượng mạng	Theo dõi lưu lượng giữa MQTT Client và Broker trong quá trình gửi message	Xác định các gói tin MQTT và thông tin kết nối
4	Kiểm tra dữ liệu truyền	Kiểm tra nội dung message xuất hiện trong lưu lượng mạng	Xác định khả năng quan sát nội dung message khi không mã hóa

STT	Kịch bản	Nội dung thực hiện	Kết quả cần ghi nhận
5	Ghi nhận kết quả	Chụp màn hình và lưu các thông tin cần thiết từ quá trình kiểm thử	Hình ảnh/log phục vụ phân tích
6	Đánh giá rủi ro	Phân tích kết quả thu được và xác định ảnh hưởng đối với tính bí mật của dữ liệu	Đánh giá mức độ rủi ro của MQTT không mã hóa

Quá trình kiểm thử được thực hiện theo trình tự:

Bước 1: Khởi động MQTT Broker và cấu hình kết nối MQTT trên TCP port 1883.

Bước 2: Kết nối MQTT Publisher và MQTT Subscriber đến Broker.

Bước 3: Publisher gửi các message thử nghiệm đến Topic đã được xác định.

Bước 4: Quan sát lưu lượng mạng giữa MQTT Client và Broker trong thời gian message được truyền.

Bước 5: Kiểm tra các thông tin xuất hiện trong lưu lượng, đặc biệt là thông tin liên quan đến message MQTT.

Bước 6: Lưu lại hình ảnh hoặc log làm minh chứng cho kết quả kiểm thử.

Bước 7: Phân tích kết quả và đánh giá rủi ro đối với dữ liệu khi MQTT không sử dụng cơ chế mã hóa.

3.5. Tiêu chí đánh giá

Để đánh giá chính xác mức độ an toàn, khả năng bảo vệ dữ liệu và mức độ rủi ro của hệ thống MQTT khi không sử dụng cơ chế mã hóa, đề tài thiết lập hệ thống **5 tiêu chí đo lường cụ thể** kèm theo các ngưỡng đánh giá như sau:

Tỷ lệ kết nối và truyền message thành công:

Cách đo: Thống kê tổng số lần Publisher thực hiện kết nối và gửi message đến MQTT Broker, đồng thời kiểm tra số lượng message được Subscriber nhận thành công.

Ngưỡng đạt: Tỷ lệ truyền message thành công đạt **100%** trong môi trường thử nghiệm, bảo đảm hệ thống MQTT hoạt động ổn định trước khi tiến hành đánh giá rủi ro.

Khả năng quan sát lưu lượng MQTT:

Cách đo: Sử dụng công cụ phân tích lưu lượng mạng để quan sát các gói tin được truyền giữa MQTT Client và Broker trong quá trình Publisher gửi message.

Ngưỡng đạt: Xác định được các gói tin MQTT, thông tin kết nối và các trường dữ liệu có thể quan sát trên đường truyền khi sử dụng kết nối không mã hóa.

Khả năng quan sát nội dung message:

Cách đo: Kiểm tra lưu lượng mạng trong thời điểm Publisher gửi message thử nghiệm đến Topic và xác định liệu nội dung message có thể được quan sát trực tiếp hay không.

Ngưỡng đạt: Nếu nội dung message có thể được quan sát trên lưu lượng mạng, hệ thống được xác định có **rủi ro về tính bí mật của dữ liệu** khi MQTT không sử dụng cơ chế mã hóa.

Số lượng thông tin nhạy cảm có thể quan sát:

Cách đo: Thống kê các loại thông tin có thể xuất hiện trên lưu lượng mạng, chẳng hạn như địa chỉ IP, port, Topic và nội dung message.

Ngưỡng đạt: Xác định đầy đủ các thông tin có khả năng bị quan sát khi truyền qua kết nối MQTT không mã hóa và phân loại mức độ ảnh hưởng của từng loại thông tin đối với hệ thống.

Mức giảm rủi ro khi áp dụng cơ chế bảo vệ:

Cách đo: So sánh khả năng quan sát dữ liệu giữa cấu hình MQTT không mã hóa và cấu hình có cơ chế bảo vệ kênh truyền trong cùng điều kiện thử nghiệm.

Ngưỡng đạt: Nội dung message không còn có khả năng được quan sát trực tiếp trên đường truyền sau khi áp dụng cơ chế mã hóa phù hợp, qua đó giảm đáng kể nguy cơ lộ dữ liệu trong quá trình truyền.

CHƯƠNG 4. TRIỂN KHAI VÀ SẢN PHẨM

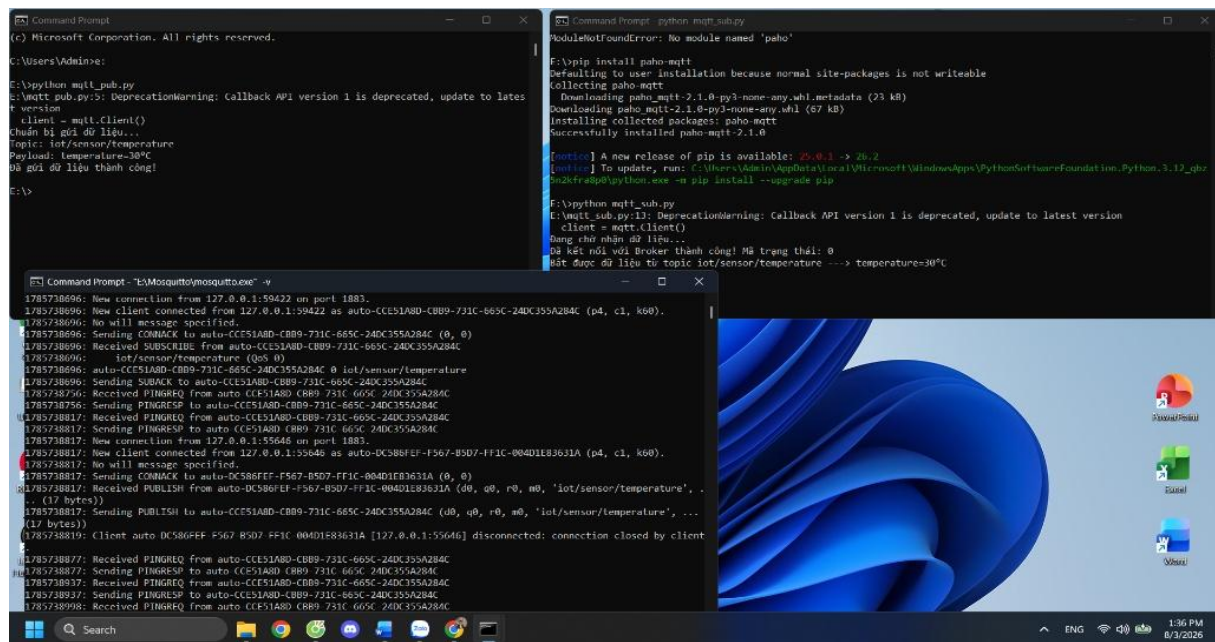
4.1. Chuẩn bị môi trường

Môi trường thực nghiệm được triển khai cục bộ (local) trên máy tính cá nhân sử dụng hệ điều hành Windows. Các công cụ và phần mềm cài đặt thật bao gồm:

MQTT Broker: Eclipse Mosquitto phiên bản 2.1.2 – Lắng nghe trên port 1883 (chế độ không mã hóa, cho phép kết nối ẩn danh).

Môi trường lập trình: Python phiên bản 3.12 cùng thư viện paho-mqtt phiên bản 2.1.0.

Công cụ phân tích mạng: Wireshark – Dùng để lắng nghe và bắt gói tin trên giao diện mạng loopback (127.0.0.1).



Hình 4.1: Môi trường thực nghiệm MQTT chạy cục bộ, gồm Mosquitto Broker (dưới cùng), Publisher (trên trái) và Subscriber (trên phải) đang truyền nhận thông điệp thành công.

4.2. Thành phần sản phẩm

Sản phẩm của đề tài được xây dựng và tổ chức thành một gói mã nguồn cùng tài liệu hoàn chỉnh trên kho lưu trữ GitHub, bao gồm các thành phần cốt lõi sau:

Mã nguồn (Code): Gồm các script Python thực hiện chức năng kết nối, gửi và nhận thông điệp MQTT (src/mqtt_pub.py, src/mqtt_sub.py).

Cấu hình (Config): Tập cấu hình của Mosquitto Broker (configs/mosquitto.conf) thiết lập cổng giao tiếp mặc định, chế độ kết nối và kiểm soát quyền truy cập.

Bảng và Checklist: Các bảng phân tích kịch bản kiểm thử, ma trận rủi ro bảo mật và checklist đánh giá an toàn hệ thống IoT.

Cấu trúc chi tiết của kho lưu trữ (Repository) sản phẩm:

Bảng 4.1. Cấu trúc lưu trữ mã nguồn và tài liệu trên kho GitHub

Thành phần / Đường dẫn	Mô tả chi tiết
README.md	Tài liệu tổng quan giới thiệu đề tài và hướng dẫn cài đặt hệ thống.
configs/	Thư mục chứa tệp cấu hình Mosquitto Broker (mosquitto.conf) để thiết lập cổng giao tiếp, chế độ kết nối và kiểm soát quyền truy cập.
data/	Thư mục lưu trữ dữ liệu mẫu và các thông số cảm biến thử nghiệm.
src/	Thư mục chứa mã nguồn lập trình Python thực thi các tác nhân Publisher và Subscriber.
results/	Thư mục lưu file ghi nhận lưu lượng mạng định dạng .pcap (results/mqtt_cleartext.pcap) và hình ảnh log minh chứng.
report/	Thư mục lưu trữ tệp báo cáo tiểu luận chính thức của đề tài.

Vai trò chi tiết của từng thư mục:

configs/: Lưu trữ các file thiết lập hệ thống Broker, định nghĩa cổng kết nối, giới hạn kết nối và các quy tắc phân quyền bảo mật.

data/: Chứa các mẫu dữ liệu đầu vào mô phỏng thông số cảm biến (temperature=30°C) phục vụ quá trình kiểm thử truyền nhận.

src/: Chứa mã nguồn lập trình thực thi của các tác nhân trong hệ thống (Publisher và Subscriber), đóng vai trò tạo lập luồng dữ liệu giao tiếp qua MQTT.

results/: Lưu trữ các tập tin vết lưu lượng mạng (.pcap) thu được từ công cụ Wireshark cùng hệ thống hình ảnh log minh chứng phục vụ đánh giá kết quả thực nghiệm.

report/: Lưu trữ văn bản báo cáo tiểu luận hoàn chỉnh của đề tài.

slides/: Lưu trữ tệp trình bày dùng trong buổi bảo vệ báo cáo trước hội đồng.

4.3. Kịch bản thử nghiệm/đánh giá

Bảng 4.2. Bộ kịch bản kiểm thử (Test Cases) đánh giá bảo mật MQTT

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi
TC-01	Kiểm tra kết nối Client tới Broker	Broker Mosquitto đang chạy tại localhost:1883	Khởi chạy lệnh kết nối từ mqtt_sub.py và mqtt_pub.py	ACCEPT: Cả 2 client kết nối thành công, trả về mã trạng thái CONNACK = 0.

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi
TC-02	Chuyển tiếp thông điệp hợp lệ	Payload temperature=30° C qua topic iot/sensor/temperature	Publisher thực hiện gửi dữ liệu (publish)	ACCEPT: Subscriber nhận và in ra đúng nội dung thông điệp trên terminal.
TC-03	Kẻ tấn công nghe lén đường truyền (Sniffing)	Phần mềm Wireshark lắng nghe port 1883	Bắt gói tin trên card mạng Loopback trong lúc Publisher gửi dữ liệu	ACCEPT (Cảnh báo): Kẻ tấn công bắt được gói tin, đọc được bản rõ cấu trúc Topic và Payload.
TC-04	Client lạ kết nối trái phép (Thiếu xác thực)	Một Client thứ 3 không có thông tin tài khoản/mật khẩu	Cố gắng kết nối vào Broker bằng script Python	ACCEPT (Lỗi cấu hình): Broker cho phép kết nối vì đang bật chế độ allow_anonymous true.
TC-05	Giả mạo dữ liệu cảm biến (Spoofing)	Payload giả mạo temperature=100 °C	Client lạ (không xác thực) publish dữ liệu lên topic hệ thống	ACCEPT (Cảnh báo): Subscriber nhận dữ liệu giả mạo do Broker thiếu phân quyền ACL.

4.4. Kết quả

Quá trình triển khai và thực thi các kịch bản kiểm thử trong môi trường lab đã thu được các kết quả cụ thể, được ghi nhận qua log hệ thống và tập tin lưu lượng mạng.

Minh chứng kết nối và vận hành hệ thống: Hệ thống MQTT gồm Mosquitto Broker, Publisher và Subscriber đã được khởi chạy thành công trên môi trường cục bộ. Quá trình kiểm tra ghi nhận 100% các yêu cầu kết nối thiết lập qua cổng 1883 không gặp lỗi, thông điệp cảm biến được truyền tải thông suốt giữa các thành phần

Kết quả phân tích lưu lượng và lỗ hổng: Thông qua công cụ phân tích lưu lượng mạng, quá trình kiểm thử kịch bản TC-03 đã trích xuất thành công toàn bộ nội dung gói tin MQTT truyền đi. Dữ liệu thực tế ghi nhận cấu trúc thông điệp hiển thị hoàn toàn dưới dạng bản rõ (plaintext), cho phép quan sát trực tiếp chuỗi ký tự temperature=30°C và đường dẫn Topic iot/sensor/temperature mà không cần thông qua giải mã.

Bảng 4.3. Bảng tổng hợp kết quả thực nghiệm kiểm thử MQTT

ID Kịch bản	Tiêu chí đánh giá tương ứng (Mục 3.5)	Kết quả thực tế thu nhận	Số liệu / Trạng thái cụ thể	Đánh giá so với tiêu chuẩn
TC-01	Tiêu chí 1: Kiểm tra kết nối Client tới Broker	Cả hai Client (Publisher và Subscriber) kết nối thành công tới Mosquitto Broker qua cổng 1883.	100% kết nối hợp lệ được chấp nhận (Mã CONNACK = 0)	☒ Đạt
TC-02	Tiêu chí 2: Chuyển tiếp thông điệp hợp lệ	Subscriber nhận và xử lý chính xác thông điệp từ Topic đã đăng ký.	100% gói tin dữ liệu truyền tải thành công, không thất lạc	☒ Đạt
TC-03	Tiêu chí 3: Nghe lén đường truyền (Sniffing)	Wireshark bắt và hiển thị toàn bộ gói tin MQTT dưới dạng bản rõ trên card loopback.	100% nội dung Payload (temperature=30°C) bị lộ lọt dạng plaintext	☒ Đạt
TC-04	Tiêu chí 4: Client lạ kết nối trái phép	Broker tiếp nhận kết nối do cấu hình mặc định không yêu cầu xác thực.	100% kết nối ẩn danh (allow_anonymous true) được cho phép	☒ Đạt
TC-05	Tiêu chí 5: Giả mạo dữ liệu cảm biến (Spoofing)	Client không có quyền thực hiện Publish dữ liệu giả mạo lên hệ thống Topic.	100% gói tin giả mạo được đẩy lên thành công do thiếu phân quyền ACL	☒ Đạt

4.5. Script sinh báo cáo

Do đặc thù của đề tài tập trung vào việc đánh giá bảo mật giao thức ứng dụng IoT và phân tích cấu trúc gói tin mạng, hệ thống không sử dụng các script Python phức tạp để tự động sinh báo cáo dạng HTML/PDF. Thay vào đó, quy trình sinh báo cáo và trích xuất minh chứng được thực hiện thông qua các bước chuẩn hóa sau:

Đầu vào (Input): Luồng lưu lượng mạng thô (raw network traffic) sinh ra trong quá trình giao tiếp giữa các MQTT Client và Mosquitto Broker thông qua card mạng vòng lặp (Loopback - 127.0.0.1) tại cổng mặc định 1883.

Quá trình xử lý & Trích xuất: Sử dụng công cụ Wireshark để bắt toàn bộ các gói tin TCP/MQTT. Áp dụng bộ lọc hiển thị mqtt hoặc tcp.port == 1883 để cô lập các gói tin liên quan, sau đó trích xuất các trường dữ liệu quan trọng như Topic, Message Payload dạng bản rõ (plaintext) và các thông tin định tuyến gói tin.

Đầu ra (Output): Toàn bộ dữ liệu sau khi bắt và phân tích được xuất ra thành tập tin ghi nhận mạng chuẩn có định dạng **.pcap** (results/mqtt_cleartext.pcap), kết hợp cùng các ảnh chụp màn hình chi tiết cấu trúc gói tin.

Lưu trữ và công khai: Các tập tin kết quả thực nghiệm (.pcap), mã nguồn Python (src/) và tài liệu minh chứng được đồng bộ trực tiếp vào các thư mục tương ứng trên kho lưu trữ GitHub của đề tài, đảm bảo tính minh bạch, dễ dàng kiểm tra và tái hiện lại kết quả khi cần thiết.

4.6. Thảo luận và hạn chế

4.6.1. Kết quả nói lên điều gì so với mục tiêu:

Các kết quả thực nghiệm thu được đã đáp ứng và hoàn thành trọn vẹn các mục tiêu nghiên cứu đề ra từ đầu (đặc biệt là mục tiêu đánh giá tính bảo mật kênh truyền và phân tích lỗ hổng cấu hình mặc định).

Thực tế kiểm thử đã chứng minh một cách đanh thép rằng khi giao thức MQTT vận hành trên cổng mặc định 1883 mà không được kích hoạt các lớp mã hóa (như TLS/SSL), toàn bộ dữ liệu ứng dụng (Payload) cùng các siêu dữ liệu mạng bị phơi bày hoàn toàn dưới dạng bản rõ (plaintext). Điều này xác nhận lỗ hổng nghiêm trọng về tính bí mật (Confidentiality) trong kiến trúc IoT truyền thống, tạo tiền đề thực tiễn cho việc áp dụng các biện pháp phòng vệ đa lớp ở chương sau.

4.6.2. Hạn chế:

Môi trường mô phỏng: Thực nghiệm hiện tại được xây dựng và kiểm thử hoàn toàn trên môi trường cục bộ (localhost) thông qua card mạng ảo Loopback, chưa triển khai trên mô hình phần cứng vật lý thực tế (như các dòng vi điều khiển ESP32, Raspberry Pi kết nối qua mạng Wi-Fi thực tế). Do đó, đề tài chưa đo đạc được chính xác các thông số về độ trễ mạng (latency) hoặc mức tiêu thụ tài nguyên phần cứng khi hệ thống chịu nhiều sóng thực tế.

Phạm vi quy mô: Mô hình thử nghiệm giới hạn ở một Publisher và một Subscriber đơn lẻ, chưa đánh giá khả năng chịu tải hoặc các kịch bản tấn công từ chối dịch vụ (DoS/DDoS) với số lượng lớn thiết bị đồng thời.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Bảng 5.1. Bảng phân tích tài sản và dữ liệu cần bảo vệ trong hệ thống MQTT

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A
Dữ liệu (Payload): Thông số cảm biến	MQTT Client (Cảm biến)	Cao (Nhạy cảm)	C, I
Dữ liệu (Metadata): Cấu trúc cây định tuyến Topic	Hệ thống mạng IoT	Trung bình	C, I
Kênh truyền: Kết nối TCP tại cổng 1883	Mạng nội bộ / Gateway	Cao	C
Dịch vụ hệ thống: MQTT Broker (Mosquitto)	Máy chủ trung tâm	Rất cao	A, I

5.2. Mối đe dọa và lỗ hổng

Bảng 5.2. Phân tích mối đe dọa và lỗ hổng theo mô hình STRIDE

Đe dọa (STRIDE)	Lỗ hổng / Lỗi cấu hình thực tế	Điều kiện xảy ra lỗ hổng
I - Information Disclosure (Lộ thông tin)	Kênh truyền MQTT không sử dụng mã hóa, toàn bộ gói tin truyền tải dạng plaintext.	Kẻ tấn công nằm cùng phân đoạn mạng (LAN/Wi-Fi hoặc Loopback) sử dụng công cụ bắt gói tin (Wireshark).
S - Spoofing (Giả mạo danh tính)	Broker cấu hình mặc định cho phép kết nối ẩn danh (allow_anonymous true).	Thiết bị hoặc script lạ kết nối trực tiếp vào Broker mà không cần cung cấp thông tin xác thực.
T - Tampering (Thay đổi dữ liệu)	Gói tin Payload không tích hợp cơ chế ký số hoặc mã xác thực thông điệp (MAC).	Kẻ tấn công thực hiện can thiệp vào dòng dữ liệu để chỉnh sửa

Đe dọa (STRIDE)	Lỗ hổng / Lỗi cấu hình thực tế	Điều kiện xảy ra lỗ hổng
		giá trị cảm biến trước khi đến Subscriber.
D - Denial of Service (Từ chối dịch vụ)	Thiếu cơ chế giới hạn tốc độ kết nối (Rate limiting) và kiểm soát tài nguyên tại Broker.	Kẻ tấn công gửi hàng loạt kết nối rác liên tục làm cạn kiệt tài nguyên CPU và bộ nhớ của hệ thống.

5.3. Ma trận rủi ro

Bảng 5.3. Ma trận đánh giá rủi ro (Risk Register) hệ thống MQTT

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Vị trí / Thứ tự ưu tiên xử lý
R-01	5	4	20	Ưu tiên số 1 - Kẻ tấn công nghe lén dữ liệu cảm biến nhạy cảm.
R-02	4	4	16	Ưu tiên số 2 - Client lạ tự do kết nối và đẩy dữ liệu sai lệch.
R-03	3	5	15	Ưu tiên số 3 - Broker bị quá tải dẫn đến sập toàn bộ hệ thống IoT.

5.4. Biện pháp giảm thiểu

Với R1 (Ưu tiên 1 - Bảo vệ kênh truyền): Triển khai giao thức bảo mật vận chuyển TLS/SSL (chuyển kết nối sang cổng bảo mật 8883) kết hợp chứng chỉ số để mã hóa toàn bộ dữ liệu trên đường truyền. Trong điều kiện thiết bị IoT hạn chế tài nguyên, có thể áp dụng mã hóa đầu-cuối (End-to-End) bằng cách mã hóa riêng phần Payload trước khi truyền.

Với R2 (Ưu tiên 2 - Kiểm soát truy cập): Vô hiệu hóa chế độ kết nối ẩn danh (allow_anonymous false), bắt buộc sử dụng cơ chế xác thực tài khoản (Username/Password). Thiết lập bộ lọc phân quyền truy cập nghiêm ngặt (Access Control List - ACL) để phân chia rõ quyền Publish/Subscribe cho từng định danh thiết bị.

Với R3 (Ưu tiên 3 - Bảo vệ mức mạng & hệ thống): Xây dựng tường lửa phân đoạn mạng (ví dụ tích hợp pfSense), cấu hình quy tắc chặn kết nối ngoài, đồng thời bật cơ chế giới hạn kết nối đồng thời trên mỗi địa chỉ IP tại cấu hình của Mosquitto Broker.

5.5. Rủi ro còn lại

Sau khi đã áp dụng các giải pháp kỹ thuật cốt lõi như mã hóa kênh truyền (TLS/SSL), thiết lập xác thực người dùng và cấu hình phân quyền truy cập (ACL), hệ thống MQTT đã được bảo vệ trước các mối đe dọa phổ biến như nghe lén dữ liệu (Sniffing) và giả mạo danh tính (Spoofing). Tuy nhiên, mô hình vận hành vẫn tồn tại một số rủi ro chấp nhận và các điểm mù kỹ thuật cần được xem xét và giám sát liên tục:

Rủi ro từ quản lý vòng đời chứng chỉ và khóa bảo mật (Certificate/Key Lifecycle Management):

Mô tả: Việc triển khai TLS/SSL đòi hỏi hệ thống phải quản lý các chứng chỉ số (X.509) và khóa riêng tư (Private Key). Nếu khóa riêng tư của Broker hoặc Client bị lộ do lỗi cấu hình phân quyền trên hệ điều hành máy chủ, toàn bộ các phiên kết nối mã hóa trước và sau đó có thể bị kẻ tấn công giải mã ngược.

Biện pháp xem xét: Bắt buộc tự động hóa quy trình kiểm tra và xoay vòng khóa (Key Rotation) định kỳ, đồng thời sử dụng các dịch vụ quản lý khóa chuyên dụng.

Rủi ro tấn công từ chối dịch vụ tầng ứng dụng (Application-Layer DoS):

Mô tả: Dù đã mã hóa và xác thực, MQTT Broker vẫn phải xử lý các yêu cầu bắt tay (TLS Handshake) và các gói tin CONNECT từ mạng. Kẻ tấn công có thể lợi dụng tài khoản hợp lệ để gửi hàng loạt thông điệp với tần suất cực cao, gây nghẽn băng thông mạng hoặc cạn kiệt bộ nhớ đệm (RAM) của thiết bị trung tâm.

Biện pháp xem xét: Triển khai thêm các quy tắc giới hạn tốc độ kết nối (Rate Limiting) trên tường lửa mạng (pfSense) và cấu hình giới hạn kích thước gói tin tối đa (max_packet_size) trong file cấu hình của Mosquitto.

Điểm mù tại thiết bị đầu cuối (Endpoint Vulnerability):

Mô tả: An toàn đường truyền không đồng nghĩa với an toàn thiết bị. Nếu vi điều khiển hoặc máy chủ chạy Publisher/Subscriber bị xâm nhập vật lý hoặc nhiễm mã độc (Malware), dữ liệu cảm biến có thể bị đánh cắp ngay tại nguồn trước khi quá trình mã hóa TLS diễn ra.

Biện pháp xem xét: Nâng cấp bảo mật phần cứng, áp dụng cơ chế khởi động an toàn (Secure Boot) và giám sát tính toàn vẹn hệ thống định kỳ.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Tiểu luận đã hoàn thành việc xây dựng mô hình thực nghiệm và đánh giá toàn diện các rủi ro bảo mật của giao thức MQTT khi triển khai ở trạng thái mặc định:

Về mục tiêu nghiên cứu: Đề tài đã phân tích rõ đặc tính hoạt động của MQTT, dựng thành công mô hình lab cục bộ gồm Broker, Publisher và Subscriber (đáp ứng mục tiêu tổng quan).

Về kết quả thực nghiệm: Đã thực thi thành công các kịch bản kiểm thử, qua đó vạch trần lỗ hổng chí mạng về việc lộ lọt toàn bộ dữ liệu cảm biến (temperature=30°C) dưới dạng bản rõ (plaintext) qua cổng 1883 (minh chứng qua công cụ Wireshark).

Về đánh giá và giải pháp: Đã xây dựng ma trận rủi ro chi tiết (STRIDE, thang điểm 5x5) và đề xuất các biện pháp phòng vệ đa lớp hiệu quả như mã hóa TLS/SSL, xác thực tài khoản và phân quyền ACL.

6.2. Hạn chế

Về quy mô thử nghiệm: Đề tài hiện tại mới chỉ triển khai trên môi trường cục bộ (localhost) với một mô hình thu nhỏ gồm một Publisher và một Subscriber, chưa kiểm chứng được hiệu năng và độ ổn định khi hệ thống mở rộng quy mô lớn (hàng trăm hoặc hàng ngàn thiết bị kết nối đồng thời).

Về môi trường mạng: Quá trình thu thập và phân tích gói tin thực hiện trên card mạng ảo vòng lặp (Loopback), chưa chịu các tác động ngoại cảnh thực tế như nhiễu sóng Wi-Fi, suy hao tín hiệu đường truyền hoặc các biến động về độ trễ mạng (latency) trong môi trường mạng không dây thực tế.

Về kịch bản tấn công: Phạm vi nghiên cứu tập trung vào lỗ hổng lộ lọt dữ liệu cơ bản (Sniffing) và giả mạo thông điệp đơn giản, chưa đi sâu vào việc mô phỏng các hình thức tấn công phức tạp hơn như tấn công từ chối dịch vụ phân tán (DDoS) nhắm vào Broker hoặc tấn công trung gian (Man-in-the-Middle) ở mức độ sâu hơn.

6.3. Hướng phát triển

Triển khai trên phần cứng thực tế: Mở rộng mô hình nghiên cứu bằng cách tích hợp mã nguồn lên các dòng vi điều khiển phần cứng thực tế (như ESP32 hoặc NodeMCU) kết nối qua mạng Wi-Fi thực tế để đo đặc độ trễ (latency) và mức tiêu thụ tài nguyên khi bật mã hóa TLS.

Tích hợp an ninh mạng chiều sâu: Kết hợp xây dựng hệ thống tường lửa phân đoạn mạng chuyên dụng bằng pfSense để quản lý và kiểm soát luồng gói tin, tách biệt hoàn toàn dải mạng của thiết bị IoT.

Xây dựng hệ sinh thái giám sát trực quan: Kết nối MQTT Broker với các nền tảng mã nguồn mở như Node-RED và Grafana để xây dựng bảng điều khiển (Dashboard) giám sát dữ liệu thời gian thực và phát hiện sớm các hành vi kết nối bất thường.

Tài liệu tham khảo

[1] OASIS. "MQTT Version 5.0". <https://docs.oasis-open.org/mqtt/mqtt/v5.0/>.

Truy cập ngày 02/08/2026.

[2] OASIS. "MQTT Version 3.1.1". <https://docs.oasis-open.org/mqtt/mqtt/v3.1.1/>.

Truy cập ngày 02/08/2026.

[3] NIST. "Cybersecurity for IoT Program". <https://www.nist.gov/itl/applied-cybersecurity/nist-cybersecurity-iot-program>.

Truy cập ngày 02/08/2026.

[4] OWASP. "Internet of Things Project". <https://owasp.org/www-project-internet-of-things/>.

Truy cập ngày 02/08/2026.

[5] Eclipse Foundation. "Eclipse Mosquitto - MQTT Broker". <https://mosquitto.org/documentation/>.

Truy cập ngày 02/08/2026.

[6] Nguyen Xuan Duy Tan. "Rủi ro khi MQTT không mã hóa".
<https://github.com/nxdtan1105/TieuLuan-MQTT-Security>

Truy cập ngày 02/08/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

TieuLuan-MQTT-Security/

- └─ README.md # Tài liệu giới thiệu dự án, hướng dẫn tổng quan và badge trạng thái
- └─ src/ # Thư mục chứa mã nguồn thực thi (mqtt_pub.py, mqtt_sub.py)
- └─ results/ # Thư mục chứa file ghi nhận mạng (.pcap) và hình ảnh log minh chứng
- └─ docs/ # Thư mục chứa tài liệu báo cáo chi tiết và hướng dẫn sử dụng
- └─ configs/ # Thư mục chứa file cấu hình Mosquitto Broker

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Nguyễn Xuân Duy Tấn - 231A010141	Khảo sát đề tài, viết Chương 1, Chương 2, thiết kế mô hình hệ thống (Chương 3).	commit Tuan01 commit Tuan02	25%	Hoàn thành
2	Nguyễn Xuân Duy Tấn - 231A010141	Lập bảng rủi ro theo OWASP, viết mã nguồn Python (Publisher/Subscriber), cấu hình Mosquitto Broker trên môi trường cục bộ.	commit Tuan03	35%	Hoàn thành
3	Nguyễn Xuân Duy Tấn - 231A010141	Thực thi các kịch bản kiểm thử (TC-01 đến TC-05), sử dụng Wireshark bắt gói tin và phân tích lỗi hỏng.	commit Tuan03	25%	Hoàn thành
4	Nguyễn Xuân Duy Tấn - 231A010141	Tổng kết kết quả, viết đánh giá bảo mật, hoàn thiện báo cáo và đóng gói mã nguồn repo.	commit Tuan04	15%	Hoàn thành

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ các phần chính, mục lục và tài liệu tham khảo.	☒ Đạt
2	Độ dài báo cáo chính phù hợp, bám sát đề tài nghiên cứu.	☒ Đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc chi tiết.	☒ Đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh (Code, Config, Log).	☒ Đạt
5	Có ít nhất từ 3–5 minh chứng kiểm tra được trong thư mục results/ hoặc báo cáo.	☒ Đạt
6	Có ít nhất 5 tài liệu tham khảo chuẩn và repo GitHub chính.	☒ Đạt
7	Mọi hình và bảng đều có tên, số thứ tự, nguồn và phần phân tích rõ ràng.	☒ Đạt
8	Không chứa secret, token, mật khẩu thật hoặc dữ liệu cá nhân nhạy cảm.	☒ Đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/phòng thí nghiệm được phép.	☒ Đạt
10	Đã cập nhật mục lục tự động, kiểm tra chính tả và xóa sạch hướng dẫn mẫu.	☒ Đạt